Programa:	3D FotoStudio 1.2	
Protección:	Cinderella 30 dias	
Objetivos:	Obtener un serial valido	
URL descarga:	---	
Dificultad:	Nula	
Herramientas:	SoftIce, w32dasm y UltraEdit32	
Cracker:	SyXe'05 [hAcK-c0d3d]	Fecha: 12-05-2005

El programa como su propio nombre indica está orientado para trabajar con imágenes, fotos, etc., y viene con una limitación Trial de 30 días, pasados los cuales lógicamente dejará de funcionar, tenemos además la opción de registro para desbloquearlo una vez haya expirado el plazo de evaluación. Hasta aquí todo perfecto, estamos creo ante un esquema típico de los TimeTrial y en este caso los puntos de eataque son innumerables pues hay muchísimos, para este caso concreto utilizaremos un ataque por la password de desbloqueo, comúnmente llamado serial number, vamos a intentar sacar el serial válido para nuestro nombre.

Comencemos...

Tras los preliminares y presentación de la víctima comenzaremos con nuestro plan de ataque, como ya hemos comentado nos hemos decidido atacar a la rutina de comprobación del serial de manera que ocurran dos cosas:

1.- Que le saquemos un serial válido. (la más correcta)
2.- Que logremos aislar los saltos a parchear para que acepte cualquier serial (tampoco está mal)

Normalmente cuando nos enfrentemos a este tipo de protecciones no solemos saber cuál será el desenlace, es decir, no sabremos con seguridad por cual de los puntos anteriores nos decantaremos o incluso otros que aquí no he enumerado pero que pueden haber (que seguro que los hay), entonces lo que se suele hacer es introducir cualquier serial en el cuadro de registro, poner un par de breakpoints para meternos en el código del programa, allí dentro localizar la rutina de verificación del serial y después tracearla, estos serán en modo general los pasos que seguiremos, pero como digo pueden cambiar está claro, cada uno lo hace como puede y sabe, dicho esto continuemos, corremos el programa, vamos al cuadro de registro e introducimos nuestro nombre y cualquier número en el campo serial, ahora antes de aceptar vamos al Softice (Sice de ahora en adelante) y ponemos:

Bpx getwindowtexta (+Intro)
Bpx hmemcpy (+Intro)

Con esto lo que estamos haciendo es decirle al Sice que detenga la ejecución del programa si hace uso de cualqueira de estas funciones, cuando lo hagamos salimos con F5 o Ctrl+d del Softice y ahora sí pulsamos aceptar, el Sice saltará automáticamente, vemos que está haciendo uso de la función hmemcpy que es utilizada para copiar datos en memoria, está claro que está recogiendo nuestros datos de registro y se los está guardando, como tenemos dos campos (nombre y serial) pulsamos F5 una vez más (si hubiera tres campos le daríamos dos veces, etc.,) después F11 para retroceder hacia el lugar desde donde se hizo la llamada que nos es más que el código de nuestra víctima, F11 la pulsaremos sólo una vez, después seguimos con F12 que lo que hace es ejecutar todas las instrucciones que encuentre hasta el siguiente ret incluído éste de esta manera iremos a parar debajo del call responsable de la llamada a hmemcpy, si seguimos estos pasos llegaremos a esta zona:

```
:00494FA1 8B45F0        mov eax, dword ptr [ebp-10]    ;eax apunta al serial válido!
:00494FA4 8B55F8        mov edx, dword ptr [ebp-08]    ;edx apunta a nuestro serial!
:00494FA7 E838EDF6FF    call 00403CE4                  ;aquí los compara…!!!
:00494FAC 7504          jne 00494FB2                   ;saltará si son diferentes → Invalid_Key...!!!
:00494FAE C645F701      mov [ebp-09], 01               ;flag de éxito activado…

* Referenced by a (U)nconditional or (C)onditional Jump at Addresses:
|:00494F87(U), :00494FAC(C)
|
:00494FB2 33C0          xor eax, eax
:00494FB4 5A            pop edx
:00494FB5 59            pop ecx
:00494FB6 59            pop ecx
:00494FB7 648910        mov dword ptr fs:[eax], edx
:00494FBA 68D74F4900    push 00494FD7
```

```
* Referenced by a (U)nconditional or
 (C)onditional Jump at Address:
|:00494FD5(U)
|
:00494FBF 8D45F0          lea eax, dword ptr [ebp-10]
:00494FC2 E891E9F6FF      call 00403958
:00494FC7 8D45F8          lea eax, dword ptr [ebp-08]
:00494FCA E889E9F6FF      call 00403958
:00494FCF C3              ret            ;falso retorno que nos lleva a :00494fd7...!!!

:00494FD0 E9A3E3F6FF      jmp 00403378
:00494FD5 EBE8            jmp 00494FBF
:00494FD7 8A45F7          mov al, byte ptr [ebp-09]  ;al pilla el valor de retorno de [ebp-09].
:00494FDA 8BE5            mov esp, ebp
:00494FDC 5D              pop ebp
:00494FDD C3              ret            ;y salimos del call.
```

Disculpad si el trozo es demasiado grande, pensé que sería bueno que os orientara, de esta manera se verá mejor lo que quiero explicar, a ver, tenemos en :00494fa1 eax apuntando al serial válido y en :00494fa4 a edx apuntando a nuestro serial, después hace una llamada en :00494fa7 que verifica si son iguales, de ser así activará el flag zero y saldrá, de no ser así no hará nada, de esta manera el flag zero estará desactivado a la salida del call y saltará en :00494fac, un salto que de producirse veremos el mensaje de error, entonces está clara la solución, cuando estemos en la instrucción :00494fa7 ponemos:

d eax

y en la ventana donde aparece la zona de memoria aparecerá el serial válido para el nombre que hayáis puesto, lo copiamos, repetimos el proceso de registro pero ahora con el nuevo serial que hemos 'pillao' jeje, lo ponemos, pulsamos aceptar y... ¡¡¡kataplummmmm...!!! mensaje de felicitación en pantalla que hace buena la hipótesis de que era el serial válido, de esta manera evitamos tener que parchear el código del programa, no hemos tocado ni un solo byte y el programa queda registrado, una maravilla... **;-)**

Para los más despistados daré los resultados para mi nombre:

Nombre: SyXe'05
Serial: 48EE0296

Últimas palabras...

Espero que tengáis suerte y sigáis probando cosillas pues hay infinidad de programas Shareware que nos ofrecen estas posibilidades, una vez parcheado el programa si te gusta pues tú verás lo que haces, aquí estamos para enseñar los errores más comunes y muchas veces evitables de los programas de este tipo, lo más fácil creo yo para curarse en salud sería distribuir los trial con las funciones 'no existentes' de manera que parchear sería casi inútil ya que la solución pasaría por reconstruir el código, francamente un coñazo, esto supongo ahorraría más de un disgusto a ciertos productos comerciales.

Ojalá os haya gustado el tuto, como siempre no hace falta decir que está orientado hacia aquellas personas que están empezando en esto, no tienen mucha experiencia y quieren aprender, por ellos me dedico a escribir los textos, pues para crackers más expertos creo que de poco sirve lo que yo pongo aquí por descontado puesto que su nivel será muchísimo más alto. Dicho esto doy por terminado el tutorial aunque sólo por hoy eeeeh, que sepáis que pronto estaremos de vuelta con otras protecciones que nos harán pasar un buen rato ;**DD**

Para cualquier duda, pregunta, crçitica o lo que sea que se ponga en contacto conmigo:

syxe00@yahoo.es
syxe00@hotmail.com